

Cybersecurity Incident Report

Brute Force Attack and Malware Redirect

Part 1: Identify the network protocol involved in the incident

The network protocols identified in the tcpdump log are DNS, HTTP, and the underlying TCP. The log first shows the source computer sending a DNS request to the DNS server to resolve `yummyrecipesforme.com`, with the server replying with the IP address `203.0.113.22`. The source computer then establishes a TCP connection to the website over HTTP (port 80) using the three-way handshake and sends an HTTP GET request. Later in the log, the source computer makes a second DNS request, this time for `greatrecipesforme.com`, and the DNS server replies with a different IP address (`192.0.2.17`). Traffic then shifts to a TCP and HTTP connection with `greatrecipesforme.com`, showing the redirection to the malicious site.

Part 2: Document the incident

The incident was reported several hours after the attack, when multiple customers emailed the `yummyrecipesforme.com` helpdesk. They reported that the website had prompted them to download a file to access free recipes, and that after running the file, the address of the website changed and their personal computers began running more slowly. When the website owner attempted to log in to the admin panel, they were unable to do so, and they contacted the website hosting provider. The cybersecurity team was then tasked with investigating the event.

To investigate, the team created a sandbox environment and used the network protocol analyzer tcpdump to observe the website's behavior. Loading `yummyrecipesforme.com` prompted the download of an executable file described as a browser update; after the file was allowed to run, the browser was redirected to `greatrecipesforme.com`, which hosts the malware. The tcpdump log captured this sequence: a DNS lookup and HTTP connection to `yummyrecipesforme.com`, followed by a new DNS lookup for `greatrecipesforme.com` and a redirected HTTP connection to its IP address. A senior analyst confirmed the website was compromised by reviewing the source code and finding that JavaScript had been added to prompt visitors to download the executable, along with a script that redirects browsers from `yummyrecipesforme.com` to `greatrecipesforme.com`.

The cybersecurity team reported that the web server was compromised through a brute force attack. A former employee repeatedly entered known default passwords for the administrative account until the correct one was guessed. The attack succeeded easily because the admin password was still set to the default password, and no additional controls were in place to prevent a brute force attempt. After gaining access, the attacker modified the website's source code to embed the malware and the redirect, then changed the administrative account password, which is why the owner was locked out. Sources for this documentation include the tcpdump traffic log, the customer helpdesk reports, and the senior analyst's review of the website source code.

Part 3: Recommend one remediation for brute force attacks

The recommended remediation is to enforce two-factor authentication (2FA), and more broadly multi-factor authentication (MFA), on the administrative account and all privileged logins. 2FA requires a second proof of identity in addition to the password, such as a one-time code from an authenticator app or a hardware security key. This directly addresses the weakness exploited here: even though the attacker guessed the default password through repeated attempts, a valid second factor would still have been required, so the guessed password alone would not have granted access to the admin panel. MFA is especially effective against brute force and password-guessing attacks because it breaks the assumption that a correct password equals a legitimate user.

2FA should be paired with a few supporting controls so the account is not relying on any single safeguard. First, replace the default password immediately and enforce a strong password policy so that credentials are not trivially guessable. Second, limit the number of failed login attempts and apply account lockout or throttling, which slows or stops the rapid repeated guessing that a brute force attack depends on. Third, monitor and log login attempts so that unusual patterns, such as many failures from one source, are detected and alerted on early. Together, strong passwords resist guessing, attempt limits slow the attack, monitoring surfaces it, and 2FA ensures that even a compromised password is not enough on its own.